

Pour monter en compétence sur la partie Microsoft Purview, ce que j'ai fait en premier, c'est suivre des cours Microsoft Learn afin de me familiariser avec M365, mais surtout avec Purview.

Ensuite, comme lire uniquement de la documentation ne sert pas à grand-chose pour monter en compétence, j'ai voulu pratiquer à côté et donc pour ça j'ai créé un environnement M365 de test qui comprend Purview ainsi que des comptes utilisateurs actifs.

Après ça, je me suis familiarisé avec l'interface administrateur du tenant, mais aussi avec l'interface Purview, en particulier les outils principaux que je vais utiliser tout au long de mon stage.

Pour mettre en place la partie pratique, j'ai conçu un fichier Excel qui contient 13 scénarios de risques possibles en entreprise liés à la fuite de données.

Le but était de réduire le coefficient de risque, qui correspond simplement à la multiplication probabilité $\times$ impact. L'objectif était d'amener ce coefficient à 0, et pour cela je devais trouver une solution adaptée à chaque risque.

Je vais donner un exemple parmi les 13 risques, mais le fichier Excel est aussi disponible sur mon GitHub.

Le premier risque, et le plus connu, est la manipulation de données sensibles sans label.

Petite parenthèse : un label est une étiquette que l'on applique sur un document sensible. Cela permet de mettre en place des mesures de sécurité, notamment la détection via DLP et des actions de blocage, ainsi que MIP (Microsoft Information Protection) qui sert au chiffrement.

Pour revenir au premier exemple, ma solution a été de détecter la manipulation de données sensibles non chiffrées. En effet, si DLP détecte un document comme sensible, cela signifie qu'il n'a pas été chiffré, sinon il ne pourrait pas être détecté en clair.

Qui dit données non chiffrées, dit aussi téléchargement en clair et partage d'informations sensibles sans protection.

Pour remédier à ce risque, j'ai mis en place deux outils : DLP et MIP, comme expliqué précédemment.

Concernant DLP, plusieurs emplacements sont possibles pour la détection, comme Appareils (endpoint), Exchange (e-mails), etc.

De mon côté, j'ai fait le choix de sélectionner uniquement OneDrive, SharePoint et Endpoint, car la majorité des documents sensibles se trouvent soit sur le poste de travail, soit sur OneDrive, soit sur SharePoint.

Je n'ai volontairement pas inclus Exchange, car j'ai préféré créer une règle dédiée aux e-mails. Cela me permet de détecter plus précisément d'où la donnée a fuité ou tenté de

fuir.

Si je mettais tous les emplacements dans une seule règle, il serait plus difficile d'identifier la source exacte.

Même si trois emplacements sont déjà sélectionnés, ce n'est pas un problème : dès qu'une donnée sensible est détectée, DLP fait déjà son travail en détectant, en bloquant et en alertant l'administrateur.

Pour être le plus efficace et le plus protecteur possible, j'ai aussi mis en place un chiffrement MIP. Ainsi, même si la donnée est partagée, elle reste chiffrée. La personne qui penserait avoir accès à la donnée sensible ne verra qu'un contenu chiffré, donc inexploitable.

Mais mon travail ne s'arrête pas là. Je dois aussi être capable d'enquêter, d'analyser l'incident et de trouver une solution pour éviter que cela ne se reproduise.

Une action simple mais très efficace est de prévenir l'utilisateur que l'action qu'il est en train d'effectuer est légitime ou non, et pourquoi.

C'est une petite action, mais qui peut avoir de grandes conséquences positives : l'utilisateur se rend compte de son erreur et peut arrêter, ce qui évite à l'administrateur de devoir intervenir en permanence.

C'est bénéfique à la fois pour l'utilisateur, qui évite de provoquer une fuite de données sensibles, et pour le SOC analyst, qui n'a pas à gérer des incidents causés par des personnes sans mauvaise intention mais qui ne savent simplement pas ce qui est autorisé ou non.

J'ai aussi appris à utiliser et à manipuler l'interface Audit, qui est un outil très important pour un SOC analyst.

Pour cela, j'ai suivi la formation "[Rechercher et investiguer avec Microsoft Purview Audit](#)" sur Microsoft Learn

Cette formation est essentielle pour bien comprendre l'interface Audit, car il faut savoir où chercher, comment chercher, mais aussi comment interpréter les résultats. Sans cette formation, je n'aurais pas totalement compris le fonctionnement de l'outil.

Je vais maintenant parler d'un deuxième exemple de risque que j'ai particulièrement aimé mettre en place : la partie Endpoint, notamment le fait de copier-coller, imprimer ou exfiltrer des documents sensibles via un périphérique de stockage externe (clé USB par exemple).

Pour chaque risque Endpoint, j'ai mis en place trois règles DLP afin de détecter précisément les actions effectuées, mais aussi une règle de chiffrement et un auto-labeling (étiquetage automatique).

La détection des données sensibles se fait grâce à DLP, et plus précisément grâce aux Sensitive Information Types (SIT), qui utilisent plusieurs techniques de détection.

Par exemple, si un document contient en clair des informations client, comme un numéro de carte bancaire, DLP va pouvoir le détecter.

À ce sujet, il est important de préciser que l'entreprise est entièrement responsable des données clients, mais aussi des rôles et des accès des utilisateurs. Même si les données sont hébergées sur des services IaaS, PaaS ou SaaS, la responsabilité de la sécurité et des accès reste celle de l'entreprise. J'ai appris cela dans la formation [SC-900](#), qui est très adaptée aux débutants.

Pour revenir à la détection, les SIT fonctionnent avec plusieurs techniques :

- Reconnaissance de format (XXXX XXXX XXXX XXXX pour une carte bancaire)
- Algorithme de Luhn, utilisé pour valider un numéro de carte
- Analyse contextuelle (mots comme "Visa", "Mastercard", "credit card")
- OCR pour analyser le texte présent dans les images
- et enfin machine learning, qui améliore la détection grâce à l'IA.

Tout cela pour dire que, dans le cadre de ma troisième semaine de stage, je poursuis ma montée en compétence sur Microsoft Purview à travers des cas pratiques et des scénarios de sécurité.